

# Backend & Database Design Specification

Double Helix Pharma UK Ltd — pharmaceutical quality & compliance platform

|          |                                         |
|----------|-----------------------------------------|
| Document | Backend & Database Design Specification |
| Version  | 1.0                                     |
| Date     | 6 June 2026                             |
| Status   | For implementation hand-off             |
| Audience | Backend / database engineer             |
| Frontend | Next.js (App Router) — built & deployed |

Confidential — prepared for internal engineering use. This document specifies the backend services and relational database to be implemented behind the existing front-end. It is implementation-ready but technology choices may be adapted to the engineer's preference where noted.

# Contents

|                                                 |           |
|-------------------------------------------------|-----------|
| <b>Contents</b>                                 | <b>2</b>  |
| <b>1. Introduction</b>                          | <b>3</b>  |
| <b>2. Application Overview</b>                  | <b>3</b>  |
| <b>3. System Architecture</b>                   | <b>4</b>  |
| <b>4. Backend &amp; API Design</b>              | <b>5</b>  |
| <b>5. Database Design</b>                       | <b>7</b>  |
| 5.3 Entity catalogue . . . . .                  | 9         |
| <b>6. Key Data Flows</b>                        | <b>14</b> |
| <b>7. Security &amp; Data Protection</b>        | <b>14</b> |
| <b>8. Non-Functional Requirements</b>           | <b>15</b> |
| <b>9. Infrastructure &amp; Deployment</b>       | <b>16</b> |
| <b>10. Appendix A — Prisma schema (excerpt)</b> | <b>16</b> |
| <b>11. Appendix B — Mermaid ER diagram</b>      | <b>17</b> |
| <b>12. Appendix C — Sample payloads</b>         | <b>18</b> |
| <b>13. Assumptions &amp; Future Work</b>        | <b>18</b> |

# 1. Introduction

**Purpose.** This document defines the backend application and relational database required to support the Double Helix Pharma UK website beyond its current static / form-only state. It is written as a hand-off specification: a backend engineer should be able to implement the system from this document without further design work.

**Scope.** In scope: the public API consumed by the website, the authenticated admin API and dashboard data model, the relational schema, integrations (email, media, analytics), security and data-protection requirements, and deployment topology. Out of scope: the front-end implementation (already built and deployed) and visual/UX design.

## 1.1 Intended audience

- Backend / full-stack engineer implementing the API and database.
- Reviewer / architect validating the design before build.
- The site owner, as a record of what the platform stores and why (GDPR accountability).

## 1.2 How to read this document

Sections 2–3 give the application and architecture context. Section 4 specifies the API surface. Section 5 is the authoritative database design (entity tables + relationships). Sections 6–9 cover data flows, security, non-functional requirements and infrastructure. Appendices provide copy-ready SQL/Prisma, a Mermaid ER diagram, and sample payloads.

**ON TECH CHOICES** Where a concrete technology is named (PostgreSQL, Prisma, Next.js Route Handlers, Auth.js, Upstash, Resend) it is a recommendation chosen to fit the existing Next.js/Vercel front-end. Equivalent substitutions are acceptable provided the data model and API contract are preserved.

# 2. Application Overview

Double Helix Pharma UK Ltd is a UK pharmaceutical quality & compliance consultancy. The website is a lead-generation and authority platform: it presents services (GMP/GDP audits, contract QP/RP/RPi cover, QMS implementation, site readiness, supplier management, GDP distribution), captures enquiries, and is intended to grow an Insights/blog, Case Studies and Industries content library.

## 2.1 Current state

- Front-end: Next.js (App Router), TypeScript, deployed on Vercel. 16 statically-rendered routes.
- Only existing server behaviour: a single contact-form endpoint that emails submissions via Resend; nothing is persisted.
- All services / FAQs / copy are currently hard-coded in the front-end (a single config module).

## 2.2 What the backend must add

- Persist and manage enquiries (a lightweight CRM), not just email them.
- A content-management layer so Insights articles, Case Studies, Services, FAQs and Industries are editable without code deploys, and rendered via the front-end.
- Newsletter subscriptions with double opt-in.
- An authenticated admin dashboard (staff) with role-based access.
- Media upload/storage for content imagery.

- Audit logging and data-protection tooling (export/erase) appropriate to a compliance business.

2.3 Goals & non-goals

| Goal                     | Description                                                                                |
|--------------------------|--------------------------------------------------------------------------------------------|
| Editable content         | Marketing can publish Insights/Case Studies without engineering.                           |
| Lead capture & tracking  | Every enquiry stored, status-tracked and attributable to a source page.                    |
| SEO continuity           | Dynamic content keeps the same metadata/JSON-LD contract the front-end already implements. |
| Compliance-grade         | Consent, retention, audit trail, least-privilege access.                                   |
| Low operational overhead | Serverless-first; managed Postgres; no servers to patch.                                   |

**Non-goals (v1):** client portals/authentication for customers, billing/payments, a public API for third parties, and multi-tenant support. The schema does not preclude these but they are not built in v1.

3. System Architecture

The system is serverless-first and co-located with the existing Vercel front-end. The browser talks to the Next.js app; server-side Route Handlers expose the API, validate input, enforce auth and talk to a managed PostgreSQL database via Prisma. Redis provides rate-limiting and caching; email, media storage and analytics are external managed services.

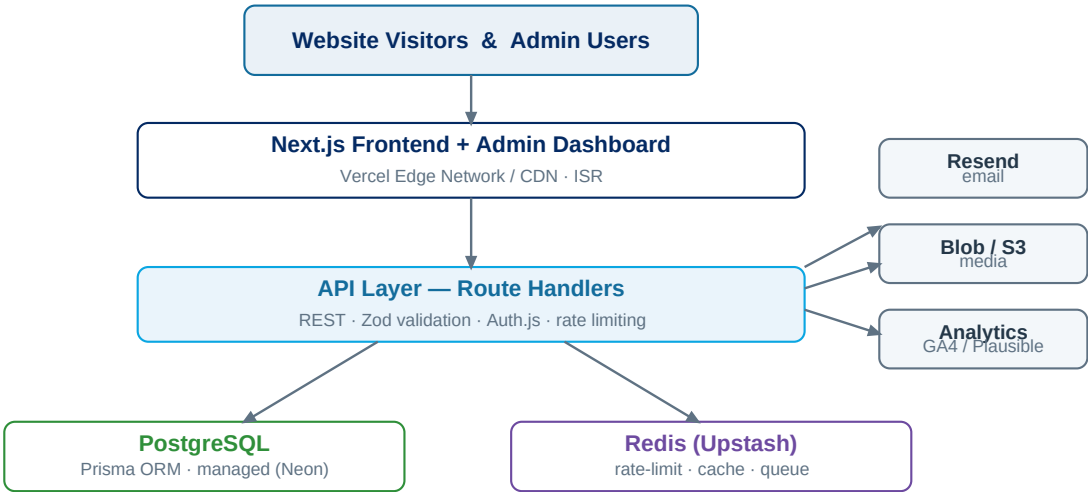


Figure 1 — High-level system architecture.

### 3.1 Recommended technology stack

| Layer                      | Choice                                  | Rationale                                                 |
|----------------------------|-----------------------------------------|-----------------------------------------------------------|
| Runtime / API              | Next.js Route Handlers (Node 20)        | Same repo/deploy as the front-end; typed end-to-end.      |
| Language                   | TypeScript (strict)                     | Shared types between API and UI.                          |
| Database                   | PostgreSQL 16 (managed — Neon)          | Relational integrity, JSONB, full-text search, branching. |
| ORM / migrations           | Prisma                                  | Type-safe queries + versioned migrations.                 |
| Validation                 | Zod                                     | One schema for runtime validation + inferred TS types.    |
| Auth                       | Auth.js (NextAuth) — credentials + RBAC | Mature session handling; httpOnly cookies.                |
| Rate-limit / cache / queue | Upstash Redis                           | Serverless Redis; @upstash/ratelimit.                     |
| Transactional email        | Resend                                  | Already integrated in the front-end.                      |
| Media storage              | Vercel Blob or AWS S3                   | Signed-URL uploads; CDN delivery.                         |
| Hosting / CI-CD            | Vercel + GitHub                         | Preview deployments; zero-config Next.js.                 |
| Error / uptime             | Sentry + Better Uptime                  | Tracing and alerting.                                     |

### 3.2 Architectural principles

- Single source of truth: the database is authoritative; the front-end reads via the API (or server components) and revalidates (ISR/on-demand) on publish.
- Layered: handler (HTTP) → service (business logic) → repository (Prisma). Validation at the boundary.
- Stateless compute: no in-process state; sessions in signed cookies, shared state in Postgres/Redis.
- Least privilege: public vs admin APIs are separate; admin requires an authenticated session and role.
- Idempotent & safe: GET never mutates; public POSTs are rate-limited and spam-guarded.

## 4. Backend & API Design

### 4.1 Conventions

- Base path /api. JSON request/response, UTF-8. All times ISO-8601 UTC.
- Resource naming is plural and kebab-case (/api/case-studies).
- Admin endpoints live under /api/admin/\* and require an authenticated session with a sufficient role.
- List endpoints support pagination (?page, ?limit, max 100), ?sort, and resource-specific filters; responses include a meta object with total/page/limit.
- Mutations validate with Zod and return the created/updated resource. Unknown fields are rejected.

### 4.2 Standard response envelope

#### Response shape

```
// success
{ "data": { ... }, "meta": { "page": 1, "limit": 20, "total": 42 } }

// error
{ "error": { "code": "VALIDATION_ERROR",
  "message": "Email is required",
  "details": [{ "path": "email", "message": "Required" }] } }
```

### 4.3 HTTP status codes

| Code                  | Meaning / when used                                     |
|-----------------------|---------------------------------------------------------|
| 200 OK                | Successful GET / PATCH.                                 |
| 201 Created           | Resource created (enquiry, subscriber, post).           |
| 204 No Content        | Successful DELETE.                                      |
| 400 Bad Request       | Malformed JSON / query.                                 |
| 401 Unauthorized      | Missing or invalid admin session.                       |
| 403 Forbidden         | Authenticated but role not permitted.                   |
| 404 Not Found         | Unknown resource / slug.                                |
| 409 Conflict          | Unique constraint (duplicate slug / email).             |
| 422 Unprocessable     | Zod validation failed.                                  |
| 429 Too Many Requests | Rate limit exceeded.                                    |
| 500 Internal          | Unhandled — logged to Sentry, generic message returned. |

### 4.4 Public API

| Method & path                    | Purpose              | Auth   | Notes                                                        |
|----------------------------------|----------------------|--------|--------------------------------------------------------------|
| POST /api/enquiries              | Submit contact form  | Public | Rate-limited; honeypot; consent required; persists + emails. |
| POST /api/subscribers            | Newsletter sign-up   | Public | Double opt-in; sends confirm email.                          |
| GET /api/subscribers/confirm     | Confirm subscription | Token  | ?token=...                                                   |
| GET /api/subscribers/unsubscribe | Unsubscribe          | Token  | ?token=...                                                   |
| GET /api/posts                   | List published posts | Public | Paginated; ?category, ?tag, ?q.                              |
| GET /api/posts/{slug}            | Single post          | Public | Published only; increments view counter.                     |
| GET /api/case-studies            | List case studies    | Public | Published only.                                              |
| GET /api/case-studies/{slug}     | Single case study    | Public | Published only.                                              |
| GET /api/services                | List services        | Public | Ordered; published only.                                     |
| GET /api/faqs                    | List FAQs            | Public | Grouped by category.                                         |
| GET /api/industries              | List industries      | Public | Published only.                                              |

## 4.5 Admin API (authenticated)

| Method & path                                                        | Purpose                          | Min role |
|----------------------------------------------------------------------|----------------------------------|----------|
| POST /api/auth/login · /logout · GET /session                        | Session lifecycle                | —        |
| GET /api/admin/enquiries                                             | List / filter / search enquiries | viewer   |
| PATCH /api/admin/enquiries/{id}                                      | Update status / assignee         | editor   |
| POST /api/admin/enquiries/{id}/notes                                 | Add follow-up note               | editor   |
| GET·POST /api/admin/posts                                            | List / create posts              | editor   |
| PATCH·DELETE /api/admin/posts/{id}                                   | Update / delete post             | editor   |
| .../admin/case-studies, /services, /faqs, /industries, /testimonials | Full CRUD (same shape)           | editor   |
| GET /api/admin/subscribers                                           | List / export subscribers (CSV)  | admin    |
| POST /api/admin/media                                                | Upload media (signed URL)        | editor   |
| GET /api/admin/audit-logs                                            | Read audit trail                 | admin    |
| GET·PATCH /api/admin/settings                                        | Read / update site settings      | admin    |
| POST /api/admin/enquiries/{id}/erase                                 | GDPR erase of a record           | admin    |

## 4.6 Validation, errors & middleware

- Every handler parses input with a Zod schema; failures return 422 with field-level details.
- A shared error handler maps known errors (Prisma P2002 → 409, auth → 401/403) and logs the rest.
- Admin routes pass through an auth middleware that resolves the session and asserts the role.
- Public mutating routes pass through a rate-limit middleware (per IP + per route).
- All responses set strict security headers; CORS is closed (same-origin) by default.

## 4.7 Background & scheduled work

| Job                      | Trigger                  | Action                                                                |
|--------------------------|--------------------------|-----------------------------------------------------------------------|
| Enquiry notifications    | On POST /api/enquiries   | Email internal team + confirmation to sender (Resend).                |
| Subscription confirm     | On sign-up / confirm     | Send / honour double opt-in email.                                    |
| Data retention sweep     | Daily cron (Vercel Cron) | Soft-delete spam + expired unconfirmed subscribers; purge per policy. |
| Sitemap / ISR revalidate | On content publish       | Trigger on-demand revalidation of affected routes.                    |
| Audit-log retention      | Monthly cron             | Archive logs older than retention window.                             |

# 5. Database Design

PostgreSQL with surrogate UUID primary keys (v7/ULID-ordered where possible for index locality). Conventions below apply to every table.

## 5.1 Conventions

- Primary key id uuid (default gen\_random\_uuid()). Natural keys (slug, email) are unique but not the PK.
- Timestamps created\_at and updated\_at (timestampz, default now()); updated\_at maintained by trigger/ORM.
- Soft delete via deleted\_at (timestampz null) on user-content and enquiries; hard delete only on GDPR erase.

- Enumerations implemented as Postgres enum types (or text + check) — listed per table.
- Foreign keys are indexed; slugs and lookup columns are indexed; full-text search via tsvector on posts.
- Money/metrics and flexible attributes use jsonb. Email stored case-insensitively (citext).

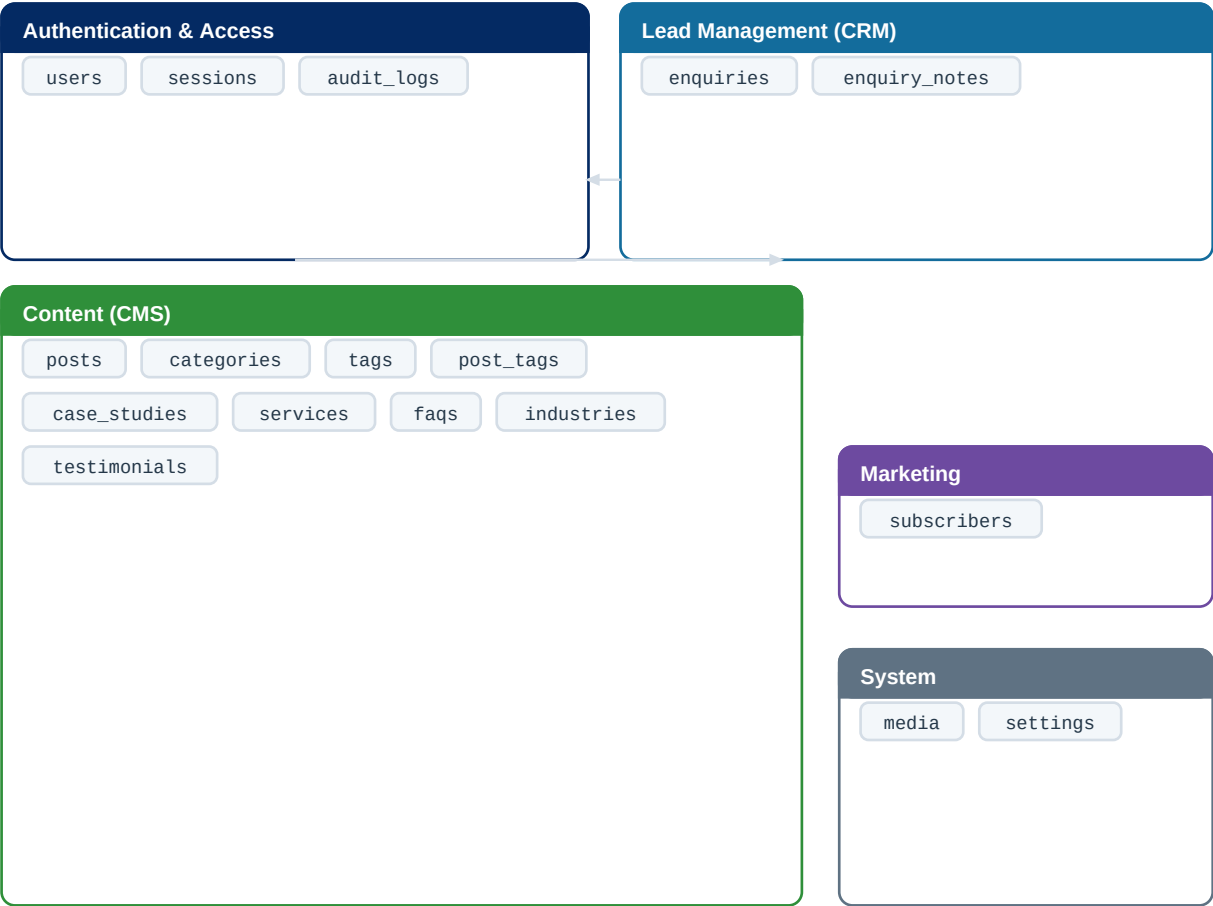


Figure 2 — Entity domain map (17 tables across five domains).

5.2 Relationships

| Parent     | Child                | Cardinality      | Foreign key                             |
|------------|----------------------|------------------|-----------------------------------------|
| users      | enquiries            | 1 : N (assignee) | enquiries.assigned_to → users.id        |
| users      | enquiry_notes        | 1 : N (author)   | enquiry_notes.author_id → users.id      |
| enquiries  | enquiry_notes        | 1 : N            | enquiry_notes.enquiry_id → enquiries.id |
| users      | posts                | 1 : N (author)   | posts.author_id → users.id              |
| categories | posts                | 1 : N            | posts.category_id → categories.id       |
| posts      | tags                 | N : N            | post_tags(post_id, tag_id)              |
| media      | posts / case_studies | 1 : N (cover)    | *.cover_image_id → media.id             |
| users      | media                | 1 : N (uploader) | media.uploaded_by → users.id            |
| users      | audit_logs           | 1 : N (actor)    | audit_logs.actor_id → users.id          |



## 5.3 Entity catalogue

### 5.3.1 users

Staff accounts for the admin dashboard.

| Column                     | Type       | Constraints                | Description                      |
|----------------------------|------------|----------------------------|----------------------------------|
| id                         | uuid       | PK                         | Surrogate key.                   |
| email                      | citext     | unique, not null           | Login identifier.                |
| password_hash              | text       | not null                   | Argon2id hash.                   |
| full_name                  | text       | not null                   | Display name.                    |
| role                       | user_role  | not null, default 'editor' | Access level.                    |
| is_active                  | boolean    | default true               | Disabled accounts cannot log in. |
| last_login_at              | timestampz | null                       | Updated on login.                |
| created_at /<br>updated_at | timestampz | default now()              | Audit timestamps.                |

Enum `user_role`: admin | editor | viewer

### 5.3.2 sessions

Server-side sessions (if DB session strategy is used; omit if JWT-only).

| Column     | Type       | Constraints        | Description           |
|------------|------------|--------------------|-----------------------|
| id         | uuid       | PK                 |                       |
| user_id    | uuid       | FK→users, not null | Owner.                |
| token_hash | text       | unique, not null   | Hashed session token. |
| expires_at | timestampz | not null           | Absolute expiry.      |
| ip_address | inet       | null               | Issued-from IP.       |
| user_agent | text       | null               | Client UA.            |
| created_at | timestampz | default now()      |                       |

### 5.3.3 enquiries

Contact-form submissions — the lightweight CRM record.

| Column  | Type           | Constraints            | Description                                         |
|---------|----------------|------------------------|-----------------------------------------------------|
| id      | uuid           | PK                     |                                                     |
| name    | text           | not null               | Submitter name.                                     |
| email   | citext         | not null               | Reply-to.                                           |
| company | text           | null                   | Organisation.                                       |
| phone   | text           | null                   | Optional phone.                                     |
| service | text           | null                   | Service of interest (matches a service slug/title). |
| message | text           | not null               | Enquiry body.                                       |
| status  | enquiry_status | default 'new'          | Pipeline state.                                     |
| source  | text           | default 'contact_form' | Origin channel.                                     |

| Column                                  | Type       | Constraints    | Description                             |
|-----------------------------------------|------------|----------------|-----------------------------------------|
| page_path                               | text       | null           | Page the form was submitted from.       |
| consent                                 | boolean    | not null       | Explicit contact consent.               |
| ip_address                              | inet       | null           | Captured for spam/audit (PII — see §7). |
| user_agent                              | text       | null           | Client UA.                              |
| assigned_to                             | uuid       | FK→users, null | Owner.                                  |
| created_at /<br>updated_at / deleted_at | timestampz |                | Lifecycle.                              |

Enum `enquiry_status`: new | in\_review | contacted | qualified | won | lost | spam

### 5.3.4 enquiry\_notes

Internal follow-up notes attached to an enquiry.

| Column     | Type       | Constraints            | Description     |
|------------|------------|------------------------|-----------------|
| id         | uuid       | PK                     |                 |
| enquiry_id | uuid       | FK→enquiries, not null | Parent enquiry. |
| author_id  | uuid       | FK→users, not null     | Note author.    |
| body       | text       | not null               | Note text.      |
| created_at | timestampz | default now()          |                 |

### 5.3.5 posts

Insights / blog articles (the primary SEO content type).

| Column                                  | Type           | Constraints         | Description                         |
|-----------------------------------------|----------------|---------------------|-------------------------------------|
| id                                      | uuid           | PK                  |                                     |
| slug                                    | text           | unique, not null    | URL segment.                        |
| title                                   | text           | not null            | Headline.                           |
| excerpt                                 | text           | null                | Summary / list teaser.              |
| body                                    | text           | not null            | Markdown/MDX content.               |
| cover_image_id                          | uuid           | FK→media, null      | Hero image.                         |
| author_id                               | uuid           | FK→users, not null  | Author.                             |
| category_id                             | uuid           | FK→categories, null | Primary category.                   |
| status                                  | content_status | default 'draft'     | Workflow state.                     |
| published_at                            | timestampz     | null                | Go-live time (supports scheduling). |
| reading_minutes                         | int            | default 0           | Computed read time.                 |
| meta_title /<br>meta_description        | text           | null                | SEO overrides.                      |
| views                                   | int            | default 0           | View counter.                       |
| search_tsv                              | tsvector       | generated           | Full-text search index.             |
| created_at /<br>updated_at / deleted_at | timestampz     |                     | Lifecycle.                          |

Enum `content_status`: draft | scheduled | published | archived

### 5.3.6 categories

Content taxonomy for posts.

| Column      | Type | Constraints      | Description |
|-------------|------|------------------|-------------|
| id          | uuid | PK               |             |
| slug        | text | unique, not null |             |
| name        | text | not null         |             |
| description | text | null             |             |

### 5.3.7 tags / post\_tags

Free-form tags and the post↔tag join table.

| Column            | Type | Constraints      | Description          |
|-------------------|------|------------------|----------------------|
| tags.id           | uuid | PK               |                      |
| tags.slug         | text | unique, not null |                      |
| tags.name         | text | not null         |                      |
| post_tags.post_id | uuid | FK→posts         | Composite PK part 1. |
| post_tags.tag_id  | uuid | FK→tags          | Composite PK part 2. |

### 5.3.8 case\_studies

Anonymised engagement write-ups for credibility.

| Column                               | Type           | Constraints      | Description                   |
|--------------------------------------|----------------|------------------|-------------------------------|
| id                                   | uuid           | PK               |                               |
| slug                                 | text           | unique, not null |                               |
| title                                | text           | not null         |                               |
| sector                               | text           | null             | Industry/sector.              |
| summary                              | text           | null             | Teaser.                       |
| challenge / approach / outcome       | text           | null             | Narrative sections.           |
| metrics                              | jsonb          | null             | e.g. {"findings_closed": 12}. |
| cover_image_id                       | uuid           | FK→media, null   |                               |
| status                               | content_status | default 'draft'  |                               |
| published_at                         | timestampz     | null             |                               |
| meta_title / meta_description        | text           | null             | SEO.                          |
| created_at / updated_at / deleted_at | timestampz     |                  |                               |

### 5.3.9 services

CMS-managed service offerings (mirrors the six built pages).

| Column                           | Type       | Constraints      | Description                  |
|----------------------------------|------------|------------------|------------------------------|
| id                               | uuid       | PK               |                              |
| slug                             | text       | unique, not null | Matches the front-end route. |
| title                            | text       | not null         |                              |
| short                            | text       | not null         | Card summary.                |
| body                             | text       | null             | Long form / sections.        |
| icon                             | text       | null             | Icon key.                    |
| order_index                      | int        | default 0        | Display order.               |
| is_published                     | boolean    | default true     |                              |
| meta_title /<br>meta_description | text       | null             | SEO.                         |
| created_at /<br>updated_at       | timestampz |                  |                              |

### 5.3.10 faqs

Question/answer pairs grouped by category.

| Column                     | Type       | Constraints  | Description               |
|----------------------------|------------|--------------|---------------------------|
| id                         | uuid       | PK           |                           |
| question                   | text       | not null     |                           |
| answer                     | text       | not null     |                           |
| category                   | text       | null         | e.g. 'General', 'Audits'. |
| order_index                | int        | default 0    |                           |
| is_published               | boolean    | default true |                           |
| created_at /<br>updated_at | timestampz |              |                           |

### 5.3.11 industries

Sector landing pages (planned growth content).

| Column             | Type    | Constraints      | Description |
|--------------------|---------|------------------|-------------|
| id                 | uuid    | PK               |             |
| slug               | text    | unique, not null |             |
| name               | text    | not null         |             |
| description / body | text    | null             |             |
| order_index        | int     | default 0        |             |
| is_published       | boolean | default true     |             |

### 5.3.12 testimonials

Short client quotes for social proof.

| Column                | Type    | Constraints  | Description |
|-----------------------|---------|--------------|-------------|
| id                    | uuid    | PK           |             |
| author_name           | text    | not null     |             |
| author_role / company | text    | null         |             |
| quote                 | text    | not null     |             |
| is_published          | boolean | default true |             |
| order_index           | int     | default 0    |             |

### 5.3.13 subscribers

Newsletter list with double opt-in.

| Column                               | Type              | Constraints       | Description        |
|--------------------------------------|-------------------|-------------------|--------------------|
| id                                   | uuid              | PK                |                    |
| email                                | citext            | unique, not null  |                    |
| status                               | subscriber_status | default 'pending' |                    |
| confirm_token /<br>unsubscribe_token | text              | unique            | Single-use tokens. |
| confirmed_at                         | timestampz        | null              |                    |
| created_at                           | timestampz        | default now()     |                    |

Enum `subscriber_status`: pending | confirmed | unsubscribed

### 5.3.14 media

Uploaded assets (images for content).

| Column         | Type       | Constraints   | Description        |
|----------------|------------|---------------|--------------------|
| id             | uuid       | PK            |                    |
| url            | text       | not null      | CDN URL.           |
| storage_key    | text       | not null      | Bucket key.        |
| filename       | text       | not null      |                    |
| alt_text       | text       | null          | Accessibility/SEO. |
| mime_type      | text       | not null      |                    |
| width / height | int        | null          |                    |
| size_bytes     | bigint     | null          |                    |
| uploaded_by    | uuid       | FK→users      |                    |
| created_at     | timestampz | default now() |                    |

### 5.3.15 audit\_logs

Append-only record of admin actions (accountability).

| Column   | Type | Constraints    | Description          |
|----------|------|----------------|----------------------|
| id       | uuid | PK             |                      |
| actor_id | uuid | FK→users, null | Who (null = system). |

| Column      | Type       | Constraints   | Description             |
|-------------|------------|---------------|-------------------------|
| action      | text       | not null      | e.g. 'post.publish'.    |
| entity_type | text       | not null      | e.g. 'post'.            |
| entity_id   | uuid       | null          | Affected row.           |
| metadata    | jsonb      | null          | Before/after / context. |
| ip_address  | inet       | null          |                         |
| created_at  | timestampz | default now() |                         |

### 5.3.16 settings

Singleton-style key/value site configuration.

| Column     | Type       | Constraints    | Description               |
|------------|------------|----------------|---------------------------|
| key        | text       | PK             | e.g. 'contact', 'social'. |
| value      | jsonb      | not null       | Structured value.         |
| updated_by | uuid       | FK→users, null |                           |
| updated_at | timestampz | default now()  |                           |

## 6. Key Data Flows

### 6.1 Contact-form submission

- 1. Visitor submits the form; the client checks the honeypot and posts JSON to POST /api/enquiries.
- 2. Rate-limit middleware (per IP) admits the request; Zod validates the body; consent must be true.
- 3. The enquiry row is inserted with status='new' and source/page\_path/ip captured.
- 4. Two emails are sent via Resend: an internal alert and a confirmation to the submitter.
- 5. 201 is returned; the front-end redirects to /thank-you (conversion event).
- 6. Staff later triage the enquiry in the dashboard (status + notes), with each change audit-logged.

### 6.2 Publishing content

- 1. Editor creates/edits a post in the dashboard (status='draft').
- 2. On 'Publish', PATCH sets status='published', published\_at=now(); an audit log is written.
- 3. The API triggers on-demand revalidation of the affected front-end routes (and sitemap).
- 4. The public GET endpoints / server components now serve the new content with full SEO metadata.

### 6.3 Newsletter double opt-in

- 1. POST /api/subscribers creates a row status='pending' with a confirm\_token; a confirm email is sent.
- 2. The recipient clicks the link → GET /confirm?token=... sets status='confirmed', confirmed\_at=now().
- 3. Every send includes an unsubscribe link bound to unsubscribe\_token (one-click, sets 'unsubscribed').

## 7. Security & Data Protection

### 7.1 Authentication & authorisation

- Admin auth via Auth.js credentials provider; passwords hashed with Argon2id; sessions in httpOnly, Secure, SameSite=Lax cookies. Optional TOTP 2FA for admin role.
- Role-based access (admin > editor > viewer) enforced server-side on every /api/admin route.
- No customer-facing accounts in v1; the public API is unauthenticated and read-/submit-only.

7.2 Input, transport & abuse

- All input validated with Zod; output encoded by the framework; parameterised queries via Prisma (no raw SQL concatenation).
- TLS everywhere (HSTS). Security headers: CSP, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.
- Public POSTs rate-limited (e.g. 5/min/IP) via Upstash; honeypot already present; optional Cloudflare Turnstile.
- Secrets only in environment variables / Vercel project settings; never committed; rotated on exposure.

7.3 UK GDPR / Data Protection Act 2018

- Lawful basis: legitimate interest / pre-contract for enquiries; consent for newsletter (double opt-in).
- Data minimisation: only the fields listed are collected; no special-category data.
- Retention: enquiries retained per policy (e.g. 24 months after last contact) then erased by the daily sweep; unconfirmed subscribers expire after 30 days.
- Data-subject rights: admin 'export' and 'erase' actions (POST ../erase) satisfy access & erasure; audit\_logs evidence accountability.
- Processors: Vercel (hosting), Neon (database), Resend (email), Upstash (transient) — all under DPAs; document international-transfer safeguards. This mirrors the published Privacy Policy.

**PII LOCATION** PII lives in users, enquiries, enquiry\_notes and subscribers. Restrict direct DB access, encrypt at rest (managed by the Postgres provider) and in transit, and keep these tables out of any analytics export.

8. Non-Functional Requirements

| Attribute           | Target / approach                                                                          |
|---------------------|--------------------------------------------------------------------------------------------|
| Performance         | p95 API < 300 ms (excl. cold start); cache read-heavy public GETs (Redis + ISR).           |
| Availability        | ≥ 99.9%; serverless auto-scale; managed DB with automated failover.                        |
| Scalability         | Stateless functions scale horizontally; DB connection pooling (PgBouncer / Prisma).        |
| Backups / DR        | Daily automated backups + point-in-time recovery (provider); restore runbook documented.   |
| Observability       | Structured JSON logs, Sentry error tracking, uptime monitor, audit_logs for admin actions. |
| Accessibility / SEO | API preserves the metadata + JSON-LD contract the front-end already renders.               |
| Maintainability     | Typed end-to-end; Prisma migrations in version control; CI runs typecheck + tests.         |

## 9. Infrastructure & Deployment

### 9.1 Environments

| Environment | Purpose                   | Database                         |
|-------------|---------------------------|----------------------------------|
| Development | Local / per-engineer      | Local Postgres or Neon branch.   |
| Preview     | Per pull-request (Vercel) | Neon preview branch (ephemeral). |
| Production  | Live site + admin         | Neon primary (backups + PITR).   |

### 9.2 CI/CD

- GitHub → Vercel: every PR gets a preview deployment; merge to main deploys production.
- CI pipeline: install → typecheck → lint → unit/integration tests → prisma migrate (deploy) → build.
- Database migrations run as a release step (prisma migrate deploy); never auto-apply on cold start.

### 9.3 Required environment variables

| Variable                        | Purpose                                           |
|---------------------------------|---------------------------------------------------|
| DATABASE_URL                    | Pooled Postgres connection string.                |
| DIRECT_URL                      | Direct (non-pooled) connection for migrations.    |
| AUTH_SECRET                     | Auth.js session/JWT signing secret.               |
| RESEND_API_KEY                  | Transactional email (already used).               |
| CONTACT_TO / CONTACT_FROM       | Enquiry notification addresses (already used).    |
| UPSTASH_REDIS_REST_URL / _TOKEN | Rate-limit / cache.                               |
| BLOB_READ_WRITE_TOKEN (or S3_*) | Media storage credentials.                        |
| NEXT_PUBLIC_SITE_URL            | Canonical origin (already used by the front-end). |
| SENTRY_DSN                      | Error reporting.                                  |

## 10. Appendix A — Prisma schema (excerpt)

prisma/schema.prisma — representative models



```

enum UserRole { admin editor viewer }
enum EnquiryStatus { new in_review contacted qualified won lost spam }
enum ContentStatus { draft scheduled published archived }

model User {
  id          String      @id @default(uuid()) @db.Uuid
  email       String      @unique
  passwordHash String
  fullName    String
  role        UserRole @default(editor)
  isActive    Boolean @default(true)
  lastLoginAt DateTime?
  enquiries   Enquiry[] @relation("assignee")
  posts       Post[]
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt
}

model Enquiry {
  id          String      @id @default(uuid()) @db.Uuid
  name        String
  email       String
  company     String?
  phone       String?
  service     String?
  message     String
  status      EnquiryStatus @default(new)
  source      String      @default("contact_form")
  pagePath    String?
  consent     Boolean
  ipAddress   String?
  assignedTo  String?      @db.Uuid
  assignee    User?        @relation("assignee", fields: [assignedTo], references: [id])
  notes       EnquiryNote[]
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt
  deletedAt   DateTime?
  @@index([status]) @@index([createdAt])
}

model Post {
  id          String      @id @default(uuid()) @db.Uuid
  slug        String      @unique
  title       String
  excerpt     String?
  body        String
  authorId    String      @db.Uuid
  author      User        @relation(fields: [authorId], references: [id])
  categoryId  String?      @db.Uuid
  status      ContentStatus @default(draft)
  publishedAt DateTime?
  views       Int          @default(0)
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt
  @@index([status, publishedAt])
}

```

## 11. Appendix B — Mermaid ER diagram

Paste into any Mermaid renderer to regenerate the full entity-relationship diagram.

ER diagram (Mermaid)

```

erDiagram
    users ||--o{ enquiries : "assigned_to"
    users ||--o{ enquiry_notes : "author"
    enquiries ||--o{ enquiry_notes : "has"
    users ||--o{ posts : "author"
    categories ||--o{ posts : "categorises"
    posts ||--o{ post_tags : ""
    tags ||--o{ post_tags : ""
    media ||--o{ posts : "cover"
    media ||--o{ case_studies : "cover"
    users ||--o{ media : "uploaded_by"
    users ||--o{ audit_logs : "actor"
    subscribers {
        uuid id
        citext email
        enum status
    }
    enquiries {
        uuid id
        citext email
        enum status
        timestampz created_at
    }
    posts {
        uuid id
        text slug
        enum status
        timestampz published_at
    }

```

## 12. Appendix C — Sample payloads

### Create enquiry

```

POST /api/enquiries
{
  "name": "Jane Smith",
  "email": "jane@acmebiotech.com",
  "company": "Acme Biotech",
  "service": "GMP & GDP Audits",
  "message": "We need a supplier audit before an MHRA inspection.",
  "consent": true,
  "website": "" // honeypot, must be empty
}

201 Created
{ "data": { "id": "0190...", "status": "new", "createdAt": "2026-06-06T10:00:00Z" } }

```

## 13. Assumptions & Future Work

- v1 assumes a small editorial team (single-digit users) and modest traffic; the design scales well beyond this.
- Content is Markdown/MDX rendered by the front-end; a richer block editor can be layered on later.
- Future: client portal & authenticated downloads, full-text site search, A/B testing, CRM/email-marketing integration, multi-language.
- If a headless CMS is preferred over the bespoke admin, the same entity model maps cleanly onto it; the public API contract should be preserved.

— End of specification —